CRISC Domain D - 100 Impossible Hard Questions

Information Technology and Security - Expert Level

CRISC Mastery Series

October 21, 2026

Warning

Extreme Difficulty

Domain D is technical but the exam tests judgment, not trivia.
Every option will look plausible.
Think like a risk practitioner advising on technology, not a technician.

Outline

1. 1. Enterprise Architecture
2. 2. IT Operations and Change Management
3. 3. Enterprise Resiliency
4. 4. Data Lifecycle Management
5. 5. SDLC and Emerging Technologies
6. 6. Information Security Principles

Q1: EA Domains

Question

An organization redesigns its business processes before redesigning software. Which EA domain drives the others?

A. Technology architecture
B. Data architecture
C. Business architecture
D. Application architecture

Q1: Explanation

Correct Answer: C

Business architecture drives the rest:

- Business architecture defines how the enterprise operates
- Application and data architectures follow business needs
- Technology architecture supports all of them

Critical Trap

Business architecture defines the "why"; the others implement the "how".

Q2: Technology Architecture Scope

Question

Which set of components belongs to technology architecture?

A. Business processes and roles
B. Application logic and interfaces
C. Networks, servers, storage, and operating systems
D. Data models and repositories

Q2: Explanation

Correct Answer: C

Technology architecture = infrastructure:

- Networks, servers, storage, operating systems
- It is the physical and logical foundation
- Applications and data sit above it

Critical Trap

Technology architecture = infrastructure, not applications.

Q3: Data Architecture Purpose

Question

What is the primary purpose of data architecture in EA?

A. Defining storage vendor strategy

B. Modeling how data is structured, integrated, and used across applications

C. Setting firewall rules

D. Managing employee access

Q3: Explanation

Correct Answer: B

Data architecture models data:

- Structure, flow, and integration
- Enables applications to use data consistently
- Supports reporting and compliance

Critical Trap

Data architecture is about modeling, not vendors.

Q4: EA Frameworks

Question

Which framework is MOST associated with enterprise architecture?

A. COBIT
B. TOGAF
C. ITIL
D. ISO 9001

Q4: Explanation

Correct Answer: B

TOGAF is the EA standard:

- The Open Group Architecture Framework
- Provides method and content for EA
- COBIT governs IT; ITIL governs service management

Critical Trap

COBIT governs; TOGAF structures the architecture.

Q5: Architecture Principle Purpose

Question

Why does EA define architecture principles?

- A To slow down projects
- B To guide consistent decisions across solutions
- C To reduce vendor competition
- D To avoid governance

Q5: Explanation

Correct Answer: B

Principles guide decisions:

- Principles guide decisions
- They align solutions with strategy
- They reduce rework and drift

Critical Trap

Principles guide, they do not block.

Q6: CMM Level Interpretation

Question

A process is described as “documented, standardized, and proactive.” Which CMM level?

- A Level 1 - Initial
- B Level 2 - Repeatable
- C Level 3 - Defined
- D Level 5 - Optimizing

Q6: Explanation

Correct Answer: C

Level 3 = Defined:

- Standardized, documented, proactive
- Level 2 is basic repeatable
- Level 5 is optimizing with metrics and continuous improvement

Critical Trap

Defined = standardized, not yet optimized.

Q7: CMM Level 5 Indicator

Question

Which indicator BEST fits CMM Level 5?

- A Documented procedures exist
- B Teams follow ad hoc processes
- C Metrics drive continuous improvement
- D Controls are undocumented

Q7: Explanation

Correct Answer: C

Level 5 = Optimizing:

- Metrics and continuous improvement
- Processes adapt and improve
- Level 3 is defined, Level 4 is managed

Critical Trap

Optimizing means improving, not just documenting.

Q8: Architecture Debt

Question

What is the PRIMARY risk of accumulated architecture debt?

A. Faster innovation
B. Increasing cost and difficulty of change
C. Better security
D. Easier integration

Q8: Explanation

Correct Answer: B

Architecture debt compounds:

- Legacy decisions limit future options
- Changes cost more over time
- Innovation slows

Critical Trap

Architecture debt compounds silently.

Q9: EA Governance

Question

Who should own EA governance decisions?

A. A single developer
B. An architecture review board or equivalent governance body
C. The vendor
D. The helpdesk

Q9: Explanation

Correct Answer: B

EA governance needs a body:

- Architecture review boards align decisions
- Cross-functional participation matters
- Single owners lack perspective

Critical Trap

EA decisions need governance, not individuals.

Q10: EA Alignment

Question

Which statement BEST describes EA alignment?

A. Aligning vendors
B. Aligning technology investments with business strategy
C. Aligning audit plans
D. Aligning tickets

Q10: Explanation

Correct Answer: B

EA aligns technology to strategy:

- Alignment is with strategy
- It turns business goals into technology choices
- It prevents orphan projects

Critical Trap

EA aligns technology to strategy, not vice versa.

Q11: Change Management Purpose

Question

What is the PRIMARY purpose of IT change management?

A. To slow down deployments

B. To control changes so they do not introduce unmanaged risk

C. To avoid documentation

D. To bypass testing

Q11: Explanation

Correct Answer: B

Change management controls risk:

- Change is inevitable
- Control reduces risk and impact
- Speed without control increases exposure

Critical Trap

Change control is risk control, not bureaucracy.

Q12: Emergency Change

Question

An emergency change bypasses normal approval. What governance should still apply?

A. No governance

B. Retrospective review, documentation, and controlled rollback readiness

C. Ignoring the change

D. No testing

Q12: Explanation

Correct Answer: B

Emergency still needs controls:

- Emergency must be documented after the fact
- Retrospective review catches issues
- Rollback readiness reduces impact

Critical Trap

Emergency is not “no governance”.

Q13: CAB Composition

Question

Who should sit on the Change Advisory Board?

A. Only developers
B. Only IT operations
C. A cross-functional group including operations, security, and business
D. Only the vendor

Q13: Explanation

Correct Answer: C

CAB must be cross-functional:

- Operations evaluates impact
- Security evaluates risk
- Business evaluates priority

Critical Trap

CAB needs cross-functional voice.

Q14: Incident vs Problem

Question

What is the MAIN distinction between incident and problem management?

A. They are identical
B. Incidents restore service; problems find root causes
C. Problems only track tickets
D. Incidents only apply to networks

Q14: Explanation

Correct Answer: B

Incident vs Problem:

- Incidents restore service quickly
- Problems eliminate root causes
- Both are needed

Critical Trap

Incident fixes the symptom; problem fixes the cause.

Q15: IT Asset Management

Question

What is the PRIMARY benefit of IT asset management?

A. Lower print costs

B. Knowing what you have and where it is, so you can protect it

C. Better lunch menu

D. Faster emails

Q15: Explanation

Correct Answer: B

You protect what you know:

- Asset inventory supports risk assessment
- Unknown assets are unmanaged
- Inventory enables lifecycle management

Critical Trap

Unknown assets are unmanaged assets.

Q16: Configuration Management

Question

Why is configuration management essential to security?

A. It speeds up printing

B. It provides known, secure baselines and detects drift

C. It reduces HR work

D. It avoids audits

Q16: Explanation

Correct Answer: B

Baselines enable security:

- Baselines define secure states
- Drift detection catches misconfigurations
- Standardization reduces risk

Critical Trap

Configurations drift silently; baselines detect them.

Q17: Release Management

Question

What is the MAIN goal of release management?

- A. Rolling out changes without testing
- B. Coordinating packaging and deployment to minimize risk and disruption
- C. Avoiding business involvement
- D. Reducing budgets

Q17: Explanation

Correct Answer: B

Release management coordinates deployment:

- Packaging, testing, deployment coordination
- Minimizes risk and disruption
- Business involvement is essential

Critical Trap

Release management is coordination, not code.

Q18: Parallel Run

Question

When is a parallel run MOST appropriate?

A. For minor cosmetic changes
B. For critical systems where downtime would cause severe impact
C. When budget is unlimited
D. When no testing is planned

Q18: Explanation

Correct Answer: B

Parallel runs protect critical systems:

- Both systems run simultaneously
- Highest assurance but highest cost
- Suitable for critical transitions

Critical Trap

Parallel runs are expensive but safest.

Q19: Phased Rollout

Question

Which changeover method BEST suits independent modules with no cross-dependencies?

A. Abrupt
B. Parallel
C. Phased
D. Big bang

Q19: Explanation

Correct Answer: C

Phased suits independent modules:

- Modules deployed one at a time
- Reduced risk of full outage
- Independent modules make phasing feasible

Critical Trap

Independent modules means phased rollout.

Q20: Abrupt Changeover

Question

Which situation MOST justifies an abrupt changeover?

A. Critical 24/7 system
B. Minor, easily reversible change with low impact
C. High-risk financial trading system
D. Regulatory reporting system

Q20: Explanation

Correct Answer: B

Abrupt is for low-risk changes:

- Abrupt is highest risk
- Suitable only for low-impact, reversible changes
- Critical systems need safer changeover

Critical Trap

Abrupt is highest risk. Only for low-risk changes.

Q21: Rollback Plan

Question

Why must a rollback plan exist before deployment?

- A To slow down the project
- B To provide a safe recovery path if the change fails
- C To satisfy vendors
- D To avoid testing

Q21: Explanation

Correct Answer: B

Rollback protects operations:

- Changes can fail
- Rollback restores service quickly
- Planning prevents panic

Critical Trap

No rollback means risky deployment.

Q22: Post-Implementation Review

Question

Which outcome signals a successful post-implementation review?

A. No documentation
B. Documented lessons and improved practices for future changes
C. Blame assigned
D. Budget increased

Q22: Explanation

Correct Answer: B

PIR drives improvement:

- Lessons documented and used
- Feedback improves future changes
- Blame discourages learning

Critical Trap

PIR without lessons is paperwork.

Q23: Production Data in Tests

Question

What is the MAIN risk of using production data for testing?

A. Faster tests
B. Unauthorized exposure of sensitive data
C. Reduced cost
D. Better collaboration

Q23: Explanation

Correct Answer: B

Sensitive data exposure:

- Production data contains PII, PHI, and secrets
- Test environments are less secure
- Masking or synthetic data avoids risk

Critical Trap

Production data in tests leaks data.

Q24: Change Ticket Traceability

Question

Why is change ticket traceability important for audits?

A. It saves money

B. It provides evidence of approval, testing, and rollback

C. It looks professional

D. It avoids testing

Q24: Explanation

Correct Answer: B

Traceability shows governance:

- Approval, testing, rollback evidence
- Supports audits and incident review
- Shows due care

Critical Trap

No trace means no evidence of control.

Q25: Shift-Left Security

Question

What does “shift-left security” mean in IT operations?

A. Security moves to the left side of the building
B. Security is integrated earlier in the development and change process
C. Security is postponed
D. Security is outsourced

Q25: Explanation

Correct Answer: B

Shift-left = earlier security:

- Security in design and build
- Cheaper to fix early
- Reduces downstream risk

Critical Trap

Shift-left is about timing, not location.

Q26: Resiliency vs Recovery

Question

Which BEST distinguishes resiliency from recovery?

A. They are the same thing
B. Resiliency avoids or limits disruption; recovery restores after disruption
C. Recovery avoids disruption; resiliency restores
D. Resiliency only applies to hardware

Q26: Explanation

Correct Answer: B

Resiliency before, recovery after:

- Resiliency prevents or limits disruption
- Recovery restores after an event
- Both are needed

Critical Trap

Resiliency anticipates; recovery restores.

Q27: Business Continuity vs Disaster Recovery

Question

Which statement is TRUE?

- A BC and DR are identical
- B DR is a subset of BC
- C BC is a subset of DR
- D Both only apply to networks

Q27: Explanation

Correct Answer: B

DR is a subset of BC:

- BC covers processes, people, and facilities
- DR restores IT systems and data
- DR supports broader BC objectives

Critical Trap

BC is broader; DR is one component.

Q28: RTO vs MTD

Question

An application must be restored within 2 hours, but the business could survive 12 hours of outage. Which statement is correct?

A. RTO = 12h, MTD = 2h

B. RTO = 2h, MTD = 12h

C. RTO = MTD

D. RTO and MTD are the same

Q28: Explanation

Correct Answer: B

RTO is inside MTD:

- RTO is the recovery target (2h)
- MTD is the maximum tolerable outage (12h)
- RTO should be less than or equal to MTD

Critical Trap

RTO must be less than or equal to MTD.

Q29: RPO Example

Question

RPO is 30 minutes. Backups run hourly. What is the issue?

A. No issue
B. Backups may lose up to 60 minutes of data, exceeding the RPO
C. RPO is too short
D. Backups run too frequently

Q29: Explanation

Correct Answer: B

Backup frequency must meet RPO:

- Hourly backups = up to 60 minutes data loss
- RPO is 30 minutes
- Need more frequent backups or replication

Critical Trap

Backup cadence must be at least as frequent as RPO.

Q30: MTD Significance

Question

Why is MTD a critical metric?

A. It sets the recovery target

B. It defines the maximum tolerable outage before severe impact

C. It measures data loss

D. It measures backup speed

Q30: Explanation

Correct Answer: B

MTD defines severe impact:

- Beyond MTD, impact becomes unacceptable
- MTD is the ceiling
- RTO is the target inside MTD

Critical Trap

MTD is the ceiling; RTO is inside.

Q31: Failover vs Failback

Question

What is failback?

A. Switching to the secondary site

B. Returning operations to the primary site after recovery

C. Reverting a change

D. Rolling back a backup

Q31: Explanation

Correct Answer: B

Failback returns to primary:

- Failover = move to secondary
- Failback = return to primary
- Both must be tested

Critical Trap

Failover moves; failback returns.

Q32: DR Test Types

Question

Which DR test provides the HIGHEST confidence?

- A Review of the DR plan
- B Tabletop exercise
- C Full failover to alternate site with real services
- D Walkthrough

Q32: Explanation

Correct Answer: C

Full failover = highest confidence:

- Tests real recovery
- Requires more resources
- Tabletop and walkthrough are cheaper but lower assurance

Critical Trap

Full failover = highest assurance, highest cost.

Q33: Backup 3-2-1 Rule

Question

Which is the 3-2-1 backup rule?

- A 3 admins, 2 vendors, 1 server
- B 3 copies of data, 2 different media, 1 offsite
- C 3 backups per day
- D 3 sites, 2 networks, 1 admin

Q33: Explanation

Correct Answer: B

3-2-1 = copies, media, offsite:

- 3 copies of data
- 2 different media types
- 1 offsite copy

Critical Trap

3-2-1 = copies, media, offsite.

Q34: Air Gap Backup

Question

Why are air-gapped backups important against ransomware?

A. They are cheaper

B. They isolate backups from network attacks and encryption

C. They are faster

D. They do not need testing

Q34: Explanation

Correct Answer: B

Air gap blocks ransomware:

- Ransomware encrypts connected backups
- Air-gapped backups stay clean
- Crucial for recovery

Critical Trap

Ransomware can encrypt connected backups.

Q35: Recovery Testing

Question

Backups exist but have never been restored. What is the KEY risk?

A. Slower backups
B. Restore may fail when needed
C. Higher storage costs
D. Less data

Q35: Explanation

Correct Answer: B

Untested restore = unreliable backup:

- Backups can be corrupt or incomplete
- Restore tests reveal issues
- Restore capability matters, not backup count

Critical Trap

Backups are useless if restore fails.

Q36: Data Classification Purpose

Question

What is the PRIMARY purpose of data classification?

A. Reduce storage
B. Determine the level of protection required
C. Simplify backups
D. Speed up reports

Q36: Explanation

Correct Answer: B

Classification drives protection:

- Sensitivity determines controls
- Enables proportionate security
- Higher class means stronger controls

Critical Trap

Classification determines controls, not storage.

Q37: Data Labeling

Question

Why is data labeling important after classification?

- A Aesthetics
- B It makes classification actionable at the data level
- C It speeds up backups
- D It reduces costs

Q37: Explanation

Correct Answer: B

Labeling operationalizes classification:

- Labels identify sensitivity at rest and in transit
- DLP tools can enforce based on labels
- Unlabeled data bypasses controls

Critical Trap

Classification without labeling is incomplete.

Q38: Data Lifecycle Stages

Question

Which stage handles disposal of data?

A. Creation
B. Use
C. Archiving
D. Destruction

Q38: Explanation

Correct Answer: D

Destruction is disposal:

- Secure disposal of data
- Meets legal and regulatory requirements
- Archiving is retention, not destruction

Critical Trap

Destruction is the disposal stage.

Q39: Data Retention Policy

Question

What does a data retention policy specify?

A. Data value only

B. How long data must be retained and when destroyed

C. Vendor preferences

D. Analytics needs

Q39: Explanation

Correct Answer: B

Retention defines duration and destruction:

- Retain for legal, regulatory, business needs
- Destroy when no longer needed
- Reduce exposure and cost

Critical Trap

Retention is how long, not value.

Q40: Data Remanence

Question

What is data remanence and why does it matter?

- A Leftover data after deletion that can be recovered
- B Data stored in RAM
- C Data in backups
- D Data in logs

Q40: Explanation

Correct Answer: A

Deletion is not destruction:

- Residual data can be recovered
- Proper destruction uses standards
- Sanitization or physical destruction

Critical Trap

Deleting files does not remove data.

Q41: DLP Purpose

Question

What is the PRIMARY purpose of a Data Loss Prevention program?

- A Prevent unauthorized data exfiltration
- B Slow down emails
- C Store data cheaply
- D Avoid backups

Q41: Explanation

Correct Answer: A

DLP prevents exfiltration:

- Detects and blocks sensitive data leaving
- Uses classification and content inspection
- Reduces insider and exfiltration risk

Critical Trap

DLP prevents loss, not storage.

Q42: Data Minimization

Question

What does data minimization require?

- A Collect as much as possible
- B Collect only the data needed for the stated purpose
- C Keep data forever
- D Store data without encryption

Q42: Explanation

Correct Answer: B

Minimization reduces exposure:

- Less data collected means less risk
- Privacy regulations often require it
- Simplifies compliance

Critical Trap

Data minimization means less is safer.

Q43: Data Governance vs Management

Question

Which statement is TRUE about data governance vs data management?

A. They are identical
B. Governance sets policy; management executes
C. Management sets policy; governance executes
D. Both apply only to backups

Q43: Explanation

Correct Answer: B

Governance vs management:

- Governance sets direction and accountability
- Management executes and enforces
- Roles must be clear

Critical Trap

Governance sets policy; management enforces.

Q44: Archiving Purpose

Question

Why is data archived rather than deleted immediately?

- A To save storage
- B To meet legal, regulatory, or contractual retention requirements
- C To avoid audits
- D To slow down systems

Q44: Explanation

Correct Answer: B

Archiving meets retention needs:

- Legal and contractual requirements
- Preserve when not in active use
- Easier and cheaper than active storage

Critical Trap

Archiving is about retention, not active use.

Q45: Secure Destruction

Question

Which is MOST appropriate for destroying data on decommissioned drives?

A. Deleting files
B. Formatting
C. Standards-based sanitization or physical destruction
D. Reusing drives

Q45: Explanation

Correct Answer: C

Standards-based destruction:

- Use recognized standards such as NIST 800-88
- Deleting or formatting leaves data recoverable
- Physical destruction may be required for high sensitivity

Critical Trap

Deleting is not destroying.

Q46: SDLC Phases

Question

Which phase of the SDLC includes budgeting and requirements definition?

A. Development
B. Implementation
C. Initiation
D. Disposal

Q46: Explanation

Correct Answer: C

Initiation sets the foundation:

- Feasibility and scope
- Requirements and budget
- Everything else depends on it

Critical Trap

Initiation includes budgeting and requirements.

Q47: SDLC Disposal

Question

What is the primary focus of the SDLC disposal phase?

A. Coding new features

B. Secure destruction of data and decommissioning

C. Training users

D. Writing requirements

Q47: Explanation

Correct Answer: B

Disposal is secure end-of-life:

- Destroy data securely
- Decommission systems
- Preserve records as required

Critical Trap

Disposal is not just deleting the system.

Q48: SDLC User Training

Question

Which SDLC phase typically includes user training?

A. Initiation
B. Development
C. Implementation
D. Disposal

Q48: Explanation

Correct Answer: C

Training happens at implementation:

- Users trained before or during rollout
- Implementation includes adoption
- Development builds, implementation deploys

Critical Trap

User training is part of implementation.

Q49: Project Risk vs SDLC Risk

Question

Which statement BEST distinguishes project risk from SDLC risk?

A. They are identical

B. Project risk focuses on objectives; SDLC risk focuses on the development process

C. SDLC risk focuses on budgets only

D. Project risk applies only to IT

Q49: Explanation

Correct Answer: B

Two kinds of risk:

- Project risk = achieving objectives
- SDLC risk = defects in design, coding, testing
- Both must be managed

Critical Trap

Project risk is about the project; SDLC risk is about the product.

Q50: Accreditation vs Certification

Question

Which statement is TRUE about accreditation and certification?

A. They are the same
B. Accreditation can be internal or external; certification is external
C. Only accreditation exists
D. Only certification is required by law

Q50: Explanation

Correct Answer: B

Accreditation vs certification:

- Accreditation = evaluation of compliance to standards
- Certification = formal recognition by external body
- Both provide assurance

Critical Trap

Accreditation can be internal; certification is external.

Q51: BYOD Risk

Question

What is the PRIMARY security risk of BYOD?

A. Cheaper devices

B. Loss of control over devices containing organizational data

C. Higher morale

D. Faster approvals

Q51: Explanation

Correct Answer: B

BYOD reduces control:

- Personal devices are outside enterprise control
- Data leakage and unpatched devices
- MDM and policy are essential

Critical Trap

BYOD trades control for convenience.

Q52: IoT Risk

Question

Which is the MOST significant security concern for IoT devices?

A. They are expensive
B. Weak default security and limited patching
C. They consume too much power
D. They are new

Q52: Explanation

Correct Answer: B

Weak defaults and limited patching:

- IoT devices often lack strong security
- Patch support is often minimal
- Network segmentation helps

Critical Trap

IoT is risky because it is unmanaged.

Q53: AI Risk

Question

Which AI risk MOST affects decision-making reliability?

A. Cost of GPUs
B. Bias and lack of explainability
C. Number of users
D. Hardware age

Q53: Explanation

Correct Answer: B

Bias and opacity:

- Biased data produces biased outcomes
- Unexplainable models cannot be governed
- Explainability is often required

Critical Trap

AI risk is often bias and opacity.

Q54: Blockchain Risk

Question

Which is a PRIMARY risk of blockchain-based systems?

A. Immutability means errors cannot be easily corrected
B. It uses too much paper
C. It is too new
D. It requires no governance

Q54: Explanation

Correct Answer: A

Immutability has trade-offs:

- Records cannot be changed easily
- Bad data persists
- Smart contract bugs are hard to fix

Critical Trap

Immutability is both strength and risk.

Q55: Quantum Risk

Question

What is the MAIN risk quantum computing poses to security?

- A Faster browsing
- B Breaking current public-key cryptography
- C Cheaper storage
- D Faster backups

Q55: Explanation

Correct Answer: B

Quantum breaks public-key crypto:

- RSA and ECC may be at risk
- Post-quantum cryptography is emerging
- Harvesting encrypted data today may reveal it later

Critical Trap

Quantum threatens current encryption.

Q56: Secure SDLC

Question

What does a secure SDLC include?

- A Security only at the end
- B Security activities embedded at each phase
- C Only testing
- D Only documentation

Q56: Explanation

Correct Answer: B

Security throughout the lifecycle:

- Requirements, design, build, test, deploy, operate
- Early security is cheaper
- End-only security misses risks

Critical Trap

Secure SDLC is security in every phase.

Q57: Threat Modeling Timing

Question

When should threat modeling be performed?

A. Only after go-live
B. During design, before implementation
C. Only during testing
D. Only after an incident

Q57: Explanation

Correct Answer: B

Threat modeling in design:

- Earliest and cheapest fix
- Shapes architecture and requirements
- Post-go-live is expensive

Critical Trap

Threat modeling is a design activity.

Q58: Code Review Purpose

Question

What is the MAIN purpose of code review?

- A To meet deadlines
- B To find defects and security issues before release
- C To train juniors only
- D To reduce code size

Q58: Explanation

Correct Answer: B

Catch issues early:

- Defects are cheaper to fix early
- Manual review complements tools
- Peer review improves quality

Critical Trap

Code review is about finding defects, not metrics.

Q59: SAST vs DAST

Question

What is the MAIN difference between SAST and DAST?

A. SAST analyzes source code statically; DAST tests running applications dynamically

B. Both are the same

C. SAST needs no source

D. DAST only scans binaries

Q59: Explanation

Correct Answer: A

SAST is static; DAST is dynamic:

- SAST scans source code without running
- DAST tests live running apps
- Both are useful and complementary

Critical Trap

SAST analyzes code; DAST exercises runtime.

Q60: Penetration Testing Scope

Question

What MUST be defined before a penetration test begins?

A. Costs only

B. Scope, rules of engagement, and authorization

C. Vendor names

D. Marketing message

Q60: Explanation

Correct Answer: B

Scope protects everyone:

- Scope protects boundaries
- Authorization protects legality
- Rules of engagement protect operations

Critical Trap

Pen tests without scope are dangerous and illegal.

Q61: CIA Triad

Question

Which of the following BEST describes the CIA triad?

A. Confidentiality, Integrity, Availability
B. Compliance, Integrity, Access
C. Control, Isolation, Assurance
D. Cybersecurity, IT, Auditing

Q61: Explanation

Correct Answer: A

CIA = Confidentiality, Integrity, Availability:

- Confidentiality = only authorized access
- Integrity = accuracy and completeness
- Availability = access when needed

Critical Trap

CIA is Confidentiality, Integrity, Availability.

Q62: Confidentiality Definition

Question

Confidentiality ensures:

A. Data is always available
B. Data has not been modified
C. Data is only accessed by authorized users
D. Data is backed up

Q62: Explanation

Correct Answer: C

Confidentiality restricts access:

- Only authorized users access data
- Enforced through access control and encryption
- Availability and integrity are separate

Critical Trap

Confidentiality is about access, not availability.

Q63: Integrity Definition

Question

Integrity ensures:

A. Data is always available
B. Data is accurate and complete
C. Data is only accessed by authorized users
D. Data is encrypted

Q63: Explanation

Correct Answer: B

Integrity = accuracy and completeness:

- Data is not altered improperly
- Hashing and controls verify integrity
- Different from confidentiality

Critical Trap

Integrity is about correctness, not access.

Q64: Availability Definition

Question

Availability ensures:

A. Data is accurate
B. Data is only accessed by authorized users
C. Data is accessible when needed
D. Data is encrypted

Q64: Explanation

Correct Answer: C

Availability = access when needed:

- Systems and data are up and reachable
- Redundancy, backups, DDoS protection support it
- Distinct from confidentiality and integrity

Critical Trap

Availability is about uptime, not secrecy.

Q65: Access Management Pillars

Question

Which group defines the four pillars of access management?

A. CIA
B. IAAA (Identification, Authentication, Authorization, Accountability)
C. SWOT
D. SMART

Q65: Explanation

Correct Answer: B

IAAA = four pillars:

- Identification = who you claim to be
- Authentication = proof of identity
- Authorization = what you can do
- Accountability = what you did

Critical Trap

IAAA is the four-pillar model.

Q66: MFA Definition

Question

Multi-factor authentication requires:

A. Two passwords
B. Two or more different authentication factors
C. One password and a username
D. Any two identifiers

Q66: Explanation

Correct Answer: B

Different factors, not duplicates:

- Factors are different types: know, have, are
- Two passwords are not MFA
- Username plus password is single-factor

Critical Trap

Two of the same factor is not MFA.

Q67: Least Privilege

Question

What does the principle of least privilege require?

A. Give everyone admin rights
B. Give users the minimum access needed to do their work
C. Deny all access
D. Rotate passwords

Q67: Explanation

Correct Answer: B

Minimum access needed:

- Minimum access reduces blast radius
- Admin rights increase risk
- Enforced via RBAC

Critical Trap

Least privilege is minimum access needed.

Q68: Segregation of Duties

Question

Segregation of duties (SoD) exists to:

A. Speed up processes
B. Prevent any single person from controlling an entire critical process
C. Reduce hiring
D. Avoid testing

Q68: Explanation

Correct Answer: B

SoD distributes control:

- Distributes control to prevent fraud and errors
- Common in finance and IT
- Reduces single-point abuse

Critical Trap

SoD prevents one person from controlling everything.

Q69: RBAC Definition

Question

Role-based access control (RBAC) assigns permissions based on:

A. User requests
B. Roles tied to job functions
C. Departments only
D. Password strength

Q69: Explanation

Correct Answer: B

RBAC = roles, not individuals:

- Roles map to job responsibilities
- Permissions assigned to roles
- Users inherit role permissions

Critical Trap

RBAC is about roles, not individuals.

Q70: Access Recertification

Question

Why is periodic access recertification necessary?

A. To save money
B. To verify that users still need their access rights
C. To reduce passwords
D. To satisfy vendors

Q70: Explanation

Correct Answer: B

Unused access is risk:

- Access accumulates over time
- Recertification removes unnecessary access
- Supports least privilege and compliance

Critical Trap

Unused access is risk that must be recertified.

Q71: Symmetric vs Asymmetric

Question

Which statement BEST distinguishes symmetric and asymmetric encryption?

A. They are identical
B. Symmetric uses one key; asymmetric uses a key pair
C. Asymmetric uses one key; symmetric uses two
D. Both use only one key

Q71: Explanation

Correct Answer: B

Symmetric vs asymmetric:

- Symmetric is fast, one shared key
- Asymmetric is slower, uses public/private keys
- Both are important

Critical Trap

Symmetric is one key; asymmetric is a key pair.

Q72: Hashing Purpose

Question

What is hashing used for?

A. Encrypting large files for confidentiality
B. Verifying integrity and storing passwords
C. Sending emails
D. Managing networks

Q72: Explanation

Correct Answer: B

Hashing = integrity:

- One-way hash verifies integrity
- Password storage uses hashes
- Hashing is not encryption

Critical Trap

Hashing is not encryption; it is integrity.

Q73: Digital Signature Provides

Question

Which properties does a digital signature provide?

A. Confidentiality and availability

B. Integrity, authenticity, and non-repudiation

C. Anonymity

D. Availability only

Q73: Explanation

Correct Answer: B

Signature provides three properties:

- Signed hash ensures integrity
- Signer identity provides authenticity
- Sender cannot deny
- Confidentiality needs encryption

Critical Trap

Signatures do NOT provide confidentiality.

Q74: Encryption vs Signature

Question

To send a message with BOTH confidentiality AND non-repudiation, the sender should:

A. Only sign the message
B. Only encrypt the message
C. Sign AND encrypt the message
D. Delete the message

Q74: Explanation

Correct Answer: C

Sign and encrypt:

- Encryption provides confidentiality
- Signature provides integrity and non-repudiation
- Both together provide all three

Critical Trap

Confidentiality plus non-repudiation means sign and encrypt.

Q75: PKI Trust Anchor

Question

What is the trust anchor in a PKI?

A. The user's browser

B. The Certificate Authority

C. The DNS server

D. The firewall

Q75: Explanation

Correct Answer: B

The CA is the trust anchor:

- CA issues and signs certificates
- Trust flows from the CA
- CA compromise breaks PKI trust

Critical Trap

The CA is the trust anchor.

Q76: CRL Purpose

Question

What is the purpose of a Certificate Revocation List (CRL)?

- A Add new certificates
- B List certificates that have been revoked before expiry
- C Encrypt data
- D Share public keys

Q76: Explanation

Correct Answer: B

Revoked is not expired:

- Revoked certs are no longer trusted
- CRLs and OCSP inform relying parties
- Expiry and revocation are different

Critical Trap

Revoked is different from expired.

Q77: Security Awareness Goal

Question

What is the primary goal of security awareness training?

- A Show completion rates
- B Build a security-conscious culture and reduce human risk
- C Meet one audit requirement
- D Replace technical controls

Q77: Explanation

Correct Answer: B

Behavior change is the goal:

- Behavior change is the goal
- Completion is a process metric
- Training complements controls

Critical Trap

Awareness is about behavior, not completion.

Q78: Phishing Defense

Question

Which combination BEST defends against phishing?

A. Only firewalls
B. Awareness, email filtering, MFA, and reporting channels
C. Disabling email
D. Blocking all links

Q78: Explanation

Correct Answer: B

Phishing defense is layered:

- Defense in depth reduces success
- MFA reduces credential theft impact
- Reporting catches missed attacks

Critical Trap

Phishing defense is layered, not single.

Q79: Insider Threat

Question

Which control BEST addresses insider threats?

A. Only firewalls
B. Least privilege, monitoring, and behavior analytics
C. Disabling email
D. Blocking all remote access

Q79: Explanation

Correct Answer: B

Insider threat requires layered monitoring:

- Least privilege limits damage
- Monitoring detects anomalies
- Behavior analytics catches unusual access

Critical Trap

Insider threat requires layered monitoring.

Q80: Data Privacy vs Security

Question

Which statement BEST distinguishes data privacy from data security?

A. They are identical

B. Privacy is about proper use and rights; security is about protecting data

C. Privacy only applies to backups

D. Security only applies to passwords

Q80: Explanation

Correct Answer: B

Privacy is not the same as security:

- Privacy is about rights and consent
- Security is about protection
- Security enables privacy

Critical Trap

Privacy is not the same as security.

Q81: GDPR Purpose

Question

Which is the PRIMARY purpose of the EU GDPR?

- A Protect personal data and privacy of EU residents
- B Reduce IT budgets
- C Ban cloud computing
- D Require encryption always

Q81: Explanation

Correct Answer: A

GDPR protects EU data subjects:

- Protects personal data and privacy
- Applies to any organization handling EU resident data
- Strong penalties for non-compliance

Critical Trap

GDPR protects EU data subjects, not just EU companies.

Q82: CCPA Beneficiary

Question

Which group is a beneficiary of the CCPA?

A. US residents in general
B. EU residents
C. California residents
D. Canadian residents

Q82: Explanation

Correct Answer: C

CCPA is about California residents:

- CCPA protects California residents
- GDPR covers EU residents
- Different laws, different regions

Critical Trap

CCPA is California residents, not all US.

Q83: HIPAA Breach Notification

Question

Under HIPAA, when must a breach be reported to OCR?

A. More than 100 individuals
B. Any IT incident
C. More than 500 individuals
D. More than 1,000 individuals

Q83: Explanation

Correct Answer: C

HIPAA threshold is 500:

- 500 or more individuals requires OCR reporting
- Fewer may still require reporting to individuals
- Threshold is a key HIPAA rule

Critical Trap

HIPAA threshold is 500 for OCR notification.

Q84: Data Subject Rights

Question

Which is an example of a data subject right under GDPR?

A. Right to unlimited access
B. Right to be forgotten
C. Right to avoid all audits
D. Right to skip training

Q84: Explanation

Correct Answer: B

Right to be forgotten:

- Right to erasure
- Right to access, correction, portability
- Enforced through processes

Critical Trap

Right to be forgotten is a GDPR right.

Q85: Privacy by Design

Question

What does privacy by design require?

A. Privacy added after go-live

B. Privacy embedded into system design from the start

C. No data collected

D. Ignoring regulations

Q85: Explanation

Correct Answer: B

Privacy starts at design:

- Privacy embedded early
- Cheaper and more effective
- Common in GDPR

Critical Trap

Privacy by design starts at design, not after launch.

Q86: Consent

Question

Valid consent under GDPR must be:

A. Implied

B. Freely given, specific, informed, and unambiguous

C. Assumed

D. Verbal only

Q86: Explanation

Correct Answer: B

Consent must be clear:

- Consent must be specific and clear
- Withdrawable at any time
- Recorded and demonstrable

Critical Trap

GDPR consent is clear, explicit, and withdrawable.

Q87: Data Breach Notification

Question

What does GDPR require after a personal data breach?

A. Nothing

B. Notify the supervisory authority within 72 hours if risk to data subjects

C. Only notify marketing

D. Delete all data

Q87: Explanation

Correct Answer: B

72-hour rule:

- 72 hours to notify supervisory authority
- Notify data subjects if high risk
- Document breaches

Critical Trap

GDPR breach notification is 72 hours.

Q88: Controller vs Processor

Question

Which statement is TRUE about controllers and processors?

- A They are the same
- B Controllers decide purposes; processors act on instructions
- C Processors decide purposes
- D Controllers only act on instructions

Q88: Explanation

Correct Answer: B

Controller decides; processor executes:

- Controller decides purpose and means
- Processor handles data on behalf
- Different legal obligations

Critical Trap

Controller decides; processor executes.

Q89: Encryption at Rest

Question

What is the primary benefit of encryption at rest?

A. Faster performance
B. Protecting data if storage media is lost or stolen
C. Reducing backup costs
D. Simplifying access

Q89: Explanation

Correct Answer: B

At-rest encryption protects lost media:

- Protects stored data
- Reduces risk of exposure
- Complementary to encryption in transit

Critical Trap

At-rest encryption protects lost media, not live misuse.

Q90: Encryption in Transit

Question

What does encryption in transit protect against?

A. Lost laptops
B. Eavesdropping and interception on networks
C. Wrongly configured firewalls
D. Lost passwords

Q90: Explanation

Correct Answer: B

In-transit encryption protects network paths:

- Protects data moving between systems
- Uses TLS, VPNs, IPSec
- Complementary to at-rest encryption

Critical Trap

In-transit encryption protects network paths.

Q91: Key Management

Question

Why is key management critical in cryptography?

A. Keys are cheap
B. Weak key management defeats the strongest encryption
C. Keys are only for backups
D. Keys are optional

Q91: Explanation

Correct Answer: B

Strong encryption plus weak key management equals broken security:

- Keys protect encrypted data
- Leaked keys break encryption
- Rotation, storage, and access control are essential

Critical Trap

Strong encryption plus weak key management equals broken security.

Q92: HSM Purpose

Question

What is the PRIMARY purpose of a Hardware Security Module?

A. Speed up networks

B. Securely store and manage cryptographic keys

C. Back up files

D. Manage DNS

Q92: Explanation

Correct Answer: B

HSM protects keys:

- HSMs protect keys
- Cryptographic operations occur inside
- Keys do not leave the HSM

Critical Trap

HSMs protect keys, not networks.

Q93: Zero Trust Principle

Question

What does the Zero Trust security model assume?

A. Trust everything inside the network

B. Trust nothing by default and verify every access

C. Trust all employees

D. Trust all vendors

Q93: Explanation

Correct Answer: B

Verify, do not trust by default:

- No implicit trust based on location
- Continuous verification
- Least privilege and segmentation

Critical Trap

Zero Trust means verify, not trust by default.

Q94: Defense in Depth

Question

What does defense in depth provide?

A. A single strong control
B. Multiple layered controls reducing single-point failure
C. More vendors
D. Less budget

Q94: Explanation

Correct Answer: B

Multiple layers, not one:

- Layers protect each other
- Independent controls reduce risk of failure
- Attackers must defeat multiple defenses

Critical Trap

Defense in depth is multiple layers, not one.

Q95: Security Control Types

Question

Which grouping BEST classifies security controls?

A. Preventive, detective, corrective

B. Red, green, blue

C. Fast, slow, medium

D. High, medium, low

Q95: Explanation

Correct Answer: A

Preventive, detective, corrective:

- Preventive = stop events
- Detective = identify events
- Corrective = reduce impact

Critical Trap

Preventive, detective, corrective are core classes.

Q96: Vulnerability vs Threat vs Risk

Question

Which statement BEST distinguishes vulnerability, threat, and risk?

A. They are identical

B. Vulnerability is weakness; threat is potential cause; risk is likelihood and impact

C. Threat is weakness; risk is cause; vulnerability is impact

D. Risk is only about costs

Q96: Explanation

Correct Answer: B

Vulnerability, threat, and risk are different:

- Vulnerability = weakness
- Threat = potential attacker or event
- Risk = likelihood and impact

Critical Trap

Vulnerability, threat, and risk are different.

Q97: Patch Management

Question

What is the primary goal of patch management?

A. Reduce costs
B. Remediate known vulnerabilities in a timely, controlled manner
C. Slow down systems
D. Add features

Q97: Explanation

Correct Answer: B

Patch management is about vulnerabilities:

- Address known vulnerabilities
- Controlled rollout reduces disruption
- Unpatched systems are prime targets

Critical Trap

Patch management is about vulnerabilities, not features.

Q98: Vulnerability Scoring

Question

What is CVSS used for?

A. Scoring the severity of vulnerabilities
B. Scoring employees
C. Measuring backups
D. Calculating budgets

Q98: Explanation

Correct Answer: A

CVSS scores vulnerabilities:

- Common Vulnerability Scoring System
- Quantifies severity
- Supports prioritization

Critical Trap

CVSS scores vulnerabilities, not risks alone.

Q99: Incident Response Stages

Question

Which is a common stage in incident response?

A. Denial

B. Preparation, detection, containment, eradication, recovery, lessons learned

C. Marketing

D. Budgeting

Q99: Explanation

Correct Answer: B

IR is a cycle:

- Structured stages ensure response quality
- Detection and containment are critical
- Lessons learned improve future response

Critical Trap

Incident response is a cycle, not a single step.

Q100: Ultimate Security Principle

Question

What is the ultimate principle of security governance?

A. Buy the newest tools

B. Align security with business objectives and manage risk continuously

C. Maximize controls

D. Eliminate all risk

Q100: Explanation

Correct Answer: B

Security exists to enable the business:

- Security supports business goals
- Risk is managed continuously
- Perfection is impossible; optimization is the goal

Critical Trap

Security exists to enable the business, not block it.

Exam Mindset Summary

Remember

- **CIA triad:** Confidentiality, Integrity, Availability
- **IAAA:** Identification, Authentication, Authorization, Accountability
- **Encryption vs Hashing:** Encryption is reversible; hashing is not
- **Signatures** provide integrity, authenticity, non-repudiation – NOT confidentiality
- **Confidentiality + Non-repudiation** = sign AND encrypt
- **Privacy** is about rights; **security** is about protection
- **Zero Trust** = verify, do not trust by default
- **Defense in depth** = layered controls
- **Patch management** addresses known vulnerabilities
- **Quantum** threatens current public-key encryption

Thank You

Good Luck on Your CRISC Exam!